

Threat Intelligence Report

Modern Cybersecurity Threats (2024-2025)
and Defense Measures

TASK - 1 | Awareness and Research Project

Prepared by

Surya

Role: Cybersecurity Analyst Intern (Simulation)

Report date: October 2026

Table of Contents

- 1. Introduction to Cybersecurity 3**
 - 1.1 What is Cybersecurity? 3
 - 1.2 Why it matters for individuals and businesses 3
 - 1.3 Current relevance 3
- 2. Threat Analysis 4**
 - 2.1 Software Supply Chain Attacks 5
 - 2.2 Ransomware Against Critical Services 6
 - 2.3 Infostealer Malware and Cloud Account Takeover 7
 - 2.4 Help-Desk Social Engineering and Identity Attacks 8
 - 2.5 Zero-Day Exploitation of Enterprise Systems 9
- 3. Conclusion and Future Scope 10**
- References 10**

1. Introduction to Cybersecurity

1.1 What is Cybersecurity?

Cybersecurity is the practice of defending computers, networks, applications and data against unauthorized access, misuse, disruption and theft. In practice it is a set of overlapping disciplines (identity and access management, network and endpoint defense, application and cloud security, monitoring, and incident response) that together aim to protect three properties of information, known as the CIA triad: **confidentiality** (only the right people can see it), **integrity** (it cannot be silently altered) and **availability** (it is there when needed).

1.2 Why it matters for individuals and businesses

For individuals, the stakes are personal: bank accounts, identity documents, private messages and family photos all sit behind a handful of passwords. For businesses the exposure is larger. A single incident can halt operations, expose customer records, trigger regulatory penalties and lawsuits, and damage the trust that took years to build. Increasingly, the two overlap: when a company is breached, it is its customers' and patients' data that ends up for sale.

1.3 Current relevance

The numbers show how quickly the problem is growing. The FBI's Internet Crime Complaint Center (IC3) received more than 1 million complaints in 2025 with reported losses of about **\$20.9 billion**, a 26% rise on 2024's \$16.6 billion and double the level of just two years earlier (Figure 1). The same report contains, for the first time, a dedicated section on artificial intelligence, linking more than 22,000 complaints and roughly \$893 million in losses to AI-enabled crime.

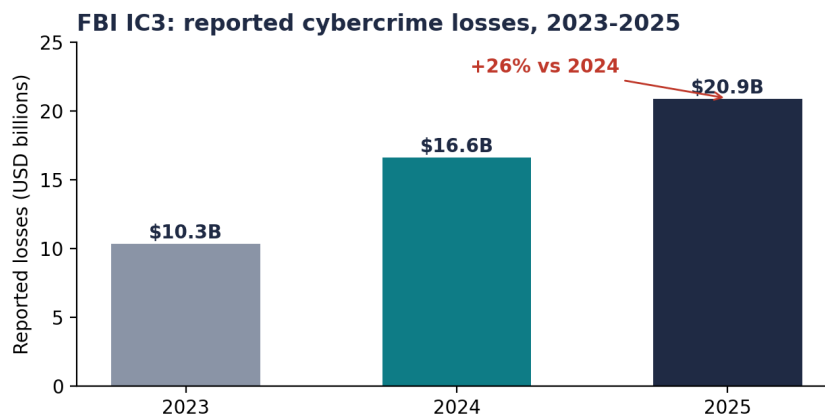


Figure 1: Reported cybercrime losses in the United States have roughly doubled in two years. Source: FBI IC3 Internet Crime Reports 2024 and 2025.

Three forces drive this: growing **digital dependency** (more of life and commerce runs online), a growing **attack surface** (cloud services, remote access, third-party vendors and connected devices), and **AI-assisted attacks** that make scams cheaper and more convincing. One caution about the data: IC3 only counts what victims report. Ransomware shows only about \$32 million in reported losses in 2025 (Figure 2), which is far below what individual incidents in this report cost, so the real picture is considerably worse than the headline.

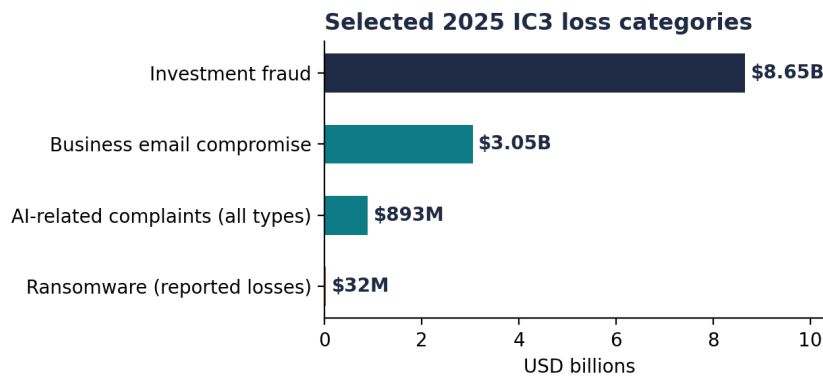


Figure 2: Selected 2025 IC3 loss categories. Ransomware is heavily under-reported to law enforcement. Source: FBI IC3 2025 Internet Crime Report.

2. Threat Analysis

This section covers five modern threats. For each one it gives a short overview, an impact analysis for individuals and organizations, a real 2024-2025 case study, a note on how a SOC analyst could detect the activity (with MITRE ATT&CK technique IDs) and practical preventive measures. The threats were chosen so that each represents a different layer of attack: trusted software, ransomware, cloud identity, human process and unpatched vulnerabilities.

Threat	Case study	Date	Headline impact
2.1 Software supply chain	XZ Utils backdoor	Mar 2024	Near-miss: CVSS 10.0 backdoor in SSH path caught weeks before wide rollout
2.2 Ransomware on critical services	Change Healthcare	Feb 2024	About 190 million people's data; \$22M ransom paid
2.3 Infostealers and cloud account takeover	Snowflake customer breaches	2024	About 165 organizations notified; no MFA on targeted accounts
2.4 Help-desk social engineering	Marks & Spencer	Apr 2025	About GBP 300M hit to operating profit; online orders suspended
2.5 Zero-day exploitation	SharePoint "ToolShell"	Jul 2025	Hundreds of victim organizations incl. government; persistent access via stolen keys

Table 1: Summary of the five threats and their case studies.

2.1 Software Supply Chain Attacks

Instead of attacking a target directly, the attacker compromises software the target already trusts: an open-source library, a build system or an update channel. One poisoned component then reaches every downstream user at once, and because it arrives through a legitimate route it slips past perimeter defenses. Open-source dependencies are a particular concern because many critical projects are maintained by a few unpaid volunteers.

Affected party	How the threat causes harm
Individuals	Rarely targeted directly, but the servers and services they rely on (banking, email, hosting) can be silently taken over. Stolen keys or credentials from compromised systems can lead to account takeover and data exposure.
Organizations	A hidden foothold on trusted infrastructure, followed by an expensive scramble to find every system containing the component, rebuild it and audit for misuse. Customers and regulators lose confidence in the vendor or the open-source dependency chain.

Case study: XZ Utils backdoor, CVE-2024-3094 (March 2024)

XZ Utils is a compression library present on most Linux systems. In 2024 it emerged that versions 5.6.0 (released 24 February) and 5.6.1 (9 March) contained a deliberately hidden backdoor, assigned the maximum CVSS score of 10.0. The malicious code targeted `sshd` through the `liblzma` library, so that an attacker holding a specific private key could run commands on the server before authentication, which would have effectively handed over remote control of affected machines. The code had been planted by a contributor account that had gradually earned the maintainer's trust. It was found largely by luck: Microsoft engineer Andres Freund noticed that SSH logins were using unexpectedly high CPU time, investigated, and raised the alarm on 29 March. CISA issued an alert advising a rollback to version 5.4.6. Because it was caught before reaching most stable distribution releases, damage was limited to rolling and testing builds (for example Fedora Rawhide, Debian unstable, Kali and Arch images).

SOC detection note (ATT&CK T1195.002, Compromise Software Supply Chain). Compare installed package versions against advisories (here xz 5.6.0 and 5.6.1); baseline normal `sshd` latency and CPU use and alert on deviations; investigate unexpected library loads or child processes of `sshd`; keep a software bill of materials (SBOM) so that exposure can be answered in minutes.

Preventive measures

- **Maintain an SBOM** and a continuously updated inventory of dependencies, with automated alerts when a component is flagged.
- **Verify and stage updates.** Check signatures and checksums, build from audited sources, and avoid auto-deploying brand-new releases straight into production.
- **Monitor runtime behavior** of critical services such as SSH so that abnormal behavior is noticed even when the code looks legitimate.

2.2 Ransomware Against Critical Services

Ransomware gangs now routinely steal data before encrypting it (double extortion) and favor victims who cannot afford downtime, such as hospitals and payment processors. Many groups operate as Ransomware-as-a-Service, renting their malware to affiliates who do the intrusions. Notably, the way in is often not a clever exploit but a stolen login on a remote-access portal.

Affected party	How the threat causes harm
Individuals	Delayed prescriptions and treatment, and exposure of medical histories, Social Security numbers and insurance details, which creates long-term identity-theft and blackmail risk.
Organizations	Weeks of downtime, ransom and recovery costs, regulatory scrutiny (for example under US health privacy law), litigation, and cascading disruption to every customer that depends on the affected provider.

Case study: Change Healthcare (February 2024)

On 21 February 2024 an affiliate of the ALPHV/BlackCat ransomware operation attacked Change Healthcare, a UnitedHealth Group subsidiary that processes a large share of US medical claims and payments. It was reported that the attackers entered through a remote-access portal that was not protected by multi-factor authentication. More than 100 applications were disrupted, pharmacies and providers struggled to process claims for weeks, and UnitedHealth paid a \$22 million ransom in Bitcoin. The ALPHV operators then vanished without paying the affiliate, who went on to work with another group, RansomHub, and threatened to leak the data anyway, showing that paying a ransom does not guarantee anything. The US health department's figure for people affected started at 100 million and was later revised to about 190 million, making it the largest healthcare data breach on record. Company costs ran into the billions of dollars.

SOC detection note (ATT&CK T1133 External Remote Services, T1078 Valid Accounts, T1567 Exfiltration, T1486 Data Encrypted for Impact). Alert on remote-access logins without MFA or from unusual locations; on very large outbound transfers (the attackers reportedly took about 6 TB); and on mass file renaming or deletion of backup and shadow copies, which usually signals encryption is imminent.

Preventive measures

- **Require MFA on every remote-access and externally reachable portal**, with no exceptions for legacy systems.
- **Keep offline or immutable backups**, test restoring from them regularly, and maintain a rehearsed incident response plan.
- **Segment networks and deploy EDR** to slow lateral movement, and plan for outages of critical third-party providers.

2.3 Infostealer Malware and Cloud Account Takeover

Infostealer malware quietly collects saved browser passwords, session cookies and tokens from infected computers. The stolen logs are sold cheaply on criminal marketplaces, and buyers simply log in with valid credentials. No software vulnerability is needed, which makes the activity hard to spot, particularly on cloud platforms where one account can reach very large datasets.

Affected party	How the threat causes harm
Individuals	Personal accounts can be hijacked, and customer records held in a breached cloud tenant can be sold or used for extortion, SIM-swap and identity fraud.
Organizations	Bulk theft of customer data without any 'hack' being visible, extortion, regulatory and legal exposure, and a difficult accountability question because the platform provider itself was not breached.

Case study: Snowflake customer breaches (2024)

In mid-2024 Google's Mandiant reported that a financially motivated group it tracks as UNC5537 had accessed the cloud data environments of about 165 organizations that use the Snowflake platform; AT&T, Ticketmaster, Santander and LendingTree were among those affected. Snowflake's own systems were not breached. Instead, the attackers used usernames and passwords harvested by infostealer malware, some dating back to 2020, against accounts that did not require MFA and whose credentials had never been rotated, in some cases for as long as four years. Mandiant noted the campaign used no particularly sophisticated technique; its scale came from the infostealer marketplace and missed opportunities to secure credentials. Snowflake responded by enforcing MFA by default for new accounts created from October 2024.

SOC detection note (ATT&CK T1555.003 Credentials from Web Browsers, T1078.004 Cloud Accounts, T1530 Data from Cloud Storage). Alert on logins to data platforms from unfamiliar IP addresses or VPN/hosting providers, unusually large queries and exports, and use of service accounts outside normal patterns. Monitor infostealer log feeds for your organization's domains.

Preventive measures

- **Enforce MFA at the tenant level** and add network allow-lists so that stolen passwords alone are useless.
- **Rotate credentials** and force resets whenever they appear in infostealer logs or breach dumps.
- **Protect the endpoints** that hold the credentials, including contractor and personal devices, with EDR and device policies.

2.4 Help-Desk Social Engineering and Identity Attacks

Rather than defeat the technology, some attackers phone the IT service desk, impersonate an employee and ask for a password reset or a new MFA device. Groups such as Scattered Spider use practised scripts, native-English speakers and personal details gathered from public sources; AI voice cloning makes the approach even more convincing. The target is the human process that guards identity.

Affected party	How the threat causes harm
Individuals	Employees have accounts hijacked, and customers see their personal details stolen and services interrupted for weeks.
Organizations	Attackers who hold a legitimate identity can move quietly through the network, escalate privileges and deploy ransomware. Outsourced service desks extend the risk beyond the organization's own walls.

Case study: Marks & Spencer (April 2025)

The attack on the UK retailer surfaced over the Easter weekend of April 2025. Online clothing orders were suspended, some stores had empty food shelves, and the company later said it expected a hit of about GBP 300 million to operating profit. Investigators, including the UK National Crime Agency, focused on Scattered Spider. The chairman told Parliament the intrusion involved a 'sophisticated impersonation' operation through a third party: someone posing as an M&S employee contacted the IT service desk run by an outsourcer, and the request was granted. Ransomware was reportedly deployed afterwards. The outsourcer, Tata Consultancy Services, stated that it found no compromise of its own network. The UK's Cyber Monitoring Centre rated the M&S and Co-op attacks together as a single event costing between GBP 270 million and GBP 440 million.

SOC detection note (ATT&CK T1566.004 Spearphishing Voice, T1656 Impersonation, T1078 Valid Accounts). Alert when a password reset or MFA-method change is followed within minutes by a login from a new device or location; flag resets on privileged accounts; and treat sudden access to domain-controller credential stores as a high-priority incident. CISA advisory AA23-320A documents this actor's methods.

Preventive measures

- **Harden identity verification** for resets: call back on a registered number, require manager approval, and apply stricter checks to privileged accounts.
- **Adopt phishing-resistant MFA** (FIDO2 security keys or passkeys) so that a social-engineered reset cannot easily bypass it.
- **Hold third-party service desks to the same standard** and rehearse with vishing simulations.

2.5 Zero-Day Exploitation of Enterprise Systems

A zero-day is a flaw that attackers exploit before the vendor has a patch. Attackers concentrate on internet-facing enterprise products such as VPNs, firewalls and collaboration servers, since a single bug can open the door to many networks at once. The window between a flaw becoming public and mass exploitation has shrunk to days or even hours, and incomplete patches can themselves be bypassed.

Affected party	How the threat causes harm
Individuals	Usually indirect: documents, credentials and personal data stored on the compromised servers can be exposed or stolen.
Organizations	Full server compromise, theft of cryptographic secrets that keep the attacker in even after patching, follow-on ransomware, and costly emergency response, forensic work and rebuilds.

Case study: Microsoft SharePoint "ToolShell", CVE-2025-53770 (July 2025)

In July 2025 attackers began exploiting a critical flaw (CVSS 9.8) in on-premises Microsoft SharePoint Server that allowed unauthenticated remote code execution. It was a variant of a bug Microsoft had only partially fixed in its 8 July update, related to an exploit chain first shown at the Pwn2Own contest in May. Eye Security spotted large-scale exploitation on 18 July; Microsoft shipped emergency patches on 20-21 July, and CISA added the flaw to its Known Exploited Vulnerabilities catalog on 20 July. Attackers installed a web shell and could steal the server's machine keys, which meant that merely applying the patch was not enough: keys had to be rotated too. Microsoft linked the activity to several China-based groups, and one, Storm-2603, was seen deploying Warlock ransomware. Later reporting counted hundreds of victim organizations, including government agencies. SharePoint Online (Microsoft 365) was not affected.

SOC detection note (ATT&CK T1190 Exploit Public-Facing Application, T1505.003 Web Shell). Hunt for suspicious POST requests to the ToolPane.aspx endpoint and for newly created .aspx files in SharePoint directories (public reporting named spinstall0.aspx as one such web shell). After patching, treat the server as potentially compromised until keys are rotated and logs reviewed.

Preventive measures

- **Patch fast, in order of risk**, using CISA's Known Exploited Vulnerabilities catalog as the priority list.
- **Reduce exposure**: do not leave legacy on-premises servers directly on the internet; place them behind a VPN, reverse proxy or Zero Trust access gateway.
- **Assume breach after patching**: rotate keys and secrets, enable EDR and AMSI, and hunt for web shells and persistence.

3. Conclusion and Future Scope

Looking across the five cases, a pattern stands out: in three of them (Change Healthcare, Snowflake and Marks & Spencer) attackers did not break the technology at all. They logged in, or talked their way into a login. The gap was identity: missing MFA, stale credentials and weak reset procedures. The other two cases show different lessons. XZ Utils warns that even trusted open-source code can be a weapon, and was caught only because one engineer was curious. ToolShell shows how quickly a half-fixed vulnerability becomes mass exploitation, and that patching is the start of the response, not the end.

This is why **proactive** security matters. Enforcing strong authentication, knowing what software you run, patching by risk, segmenting networks and monitoring continuously are all cheaper than the recovery bills described in this report. Defenses also have to cover people and processes, such as the help desk, not just servers.

Looking ahead, AI will strengthen both sides. Attackers will use it for more convincing voice, video and text deception, which the FBI has already begun to track separately; defenders will use it to sift huge volumes of logs and spot anomalies humans would miss. Likely priorities for the next few years include phishing-resistant authentication, wider use of SBOMs, Zero Trust access, and tested recovery plans for critical suppliers.

Finally, the specific threats named here will change. What stays valuable is the habit of continuous learning: reading advisories from CISA and vendors, practising detection against frameworks such as MITRE ATT&CK, and questioning unusual requests. A natural next step for this work would be to turn the detection notes above into working detection rules and test them in a home lab.

References

- [1] FBI Internet Crime Complaint Center, *2025 Internet Crime Report* (April 2026): https://www.ic3.gov/AnnualReport/Reports/2025_IC3Report.pdf
- [2] SpyCloud, *FBI Internet Crime Report 2025 analysis*: <https://spycloud.com/blog/fbi-internet-crime-report-2025/>
- [3] The Hacker News, *Urgent: Secret Backdoor Found in XZ* (March 2024): <https://thehackernews.com/2024/03/urgent-secret-backdoor-found-in-xz.html>
- [4] Qualys, *XZ Utils SSHd Backdoor* (March 2024): <https://blog.qualys.com/vulnerabilities-threat-research/2024/03/29/xz-utils-sshd-backdoor>
- [5] TechCrunch, *How the ransomware attack at Change Healthcare went down: a timeline*: <https://techcrunch.com/2024/12/18/how-the-ransomware-attack-at-change-healthcare-went-down-a-timeline/>
- [6] Security Affairs, *Change Healthcare data breach impacts 190 million people*: <https://securityaffairs.com/173467/data-breach/change-healthcare-data-breach-190m-people.html>
- [7] CSO Online, *Change Healthcare data breach exposed 100 million US health records*: <https://www.csoonline.com/article/3588766/change-healthcare-data-breach-exposed-only-100-million-us-health-records.html>
- [8] Axios, *About 165 orgs may have been affected in Snowflake incident* (June 2024): <https://www.axios.com/2024/06/11/165-orgs-snowflake-data-breaches>
- [9] SiliconANGLE, *Mandiant finds 165 Snowflake customers were targeted* (June 2024): <https://siliconangle.com/2024/06/10/mandiant-finds-165-snowflake-customers-targeted-hacking-campaign/>
- [10] Retail Systems, *M&S cyber attack to cost GBP 300m* (2025): https://retail-systems.com/rs/MS_Cyber_Attack_To_Cost_300m_With_Disruption_Until_July.php
- [11] Computing, *M&S ends service contract with TCS after cyberattack* (2025): <https://www.computing.co.uk/news/2025/security/m-s-ends-contract-with-tcs>
- [12] CISA, *Scattered Spider advisory AA23-320A*: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a>
- [13] KrebsOnSecurity, *Microsoft Fix Targets Attacks on SharePoint Zero-Day* (July 2025): <https://krebsonsecurity.com/2025/07/microsoft-fix-targets-attacks-on-sharepoint-zero-day/>
- [14] Cyber Security News, *Microsoft releases mitigations for SharePoint zero-day* (2025): <https://cybersecuritynews.com/sharepoint-zero-day-patch/amp/>
- [15] MITRE ATT&CK knowledge base: <https://attack.mitre.org>
- [16] CISA Known Exploited Vulnerabilities Catalog: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [17] OWASP Foundation: <https://owasp.org>